

NIST HGA Security Risk Assessment & Mitigation

Project

Table of Contents

NIST HGA Security Risk Assessment & Mitigation Project	1
Table of Contents.....	1
Executive Summary.....	1
Foundational Inventories	2
Asset Inventory	3
Threat Inventory	4
Security Vulnerabilities Inventory	5
Current Security Controls and Policies	5
New Security Controls and Policies	6
Top 4 Assets, Threats and Vulnerabilities	7
Critical Assets	7
Threats.....	8
Vulnerabilities	8
A/T/V Likelihood Table: Stated Assumptions	8
A/T/V Table: Likelihood (%).....	9
Mapping: Asset/Vulnerability Pairs	10
Mapping: Risk Impact Table	11
Scenario 1: Residual Risk with HGA's Current Security Posture	11
Scenario 2: Residual Risk with New CISO's Controls Applied.....	14
Scenario 3: Residual Risk with Management-Operational-Technical (MOT) Controls .	16
Scenario 4 (Prevention Step P1): Applying RBAC to the Highest-Risk Vulnerability	18
Scenario 8 (Optimized security Mixed Strategy): Candidate Controls from Scenario 3	25
8.1. 2FA (Targets V1, TV reduction, 50%)	25
8.2. VPN (Targets V8, TV reduction, 50%)	25

8.3. Redundant Server (Targets A7, RI reduction, 35%)	25
8.4. Mirror Site (Targets A1, RI reduction, 35%)	26
Ranking of Total Asset Reduction	26
Strategy Comparison.....	26
Summary Table.....	27
Conclusion.....	28

Executive Summary

This project applies a quantitative risk model to the NIST SP 800-12 HGA payroll case study. It scores four Critical Assets (Payroll Funds, Employee Database, LAN Server, Mainframe) against four Threats and four Vulnerabilities. Starting from a worst-case baseline, it measures how each layer of controls reduces residual risk: current controls, the new CISO's controls, and Management-Operational-Technical (MOT) controls. It then tests two treatment strategies, Prevention (reducing likelihood) and Response (reducing impact), plus a Mixed Strategy comparison.

Stage	Controls applied	Total Asset Risk	Cumulative reduction vs. Scenario 1
Scenario 1	Current controls (CSCP1–20)	2,171.50	—
Scenario 2	+ New CISO controls	1,490.00	31.4%
Scenario 3	+ MOT controls	1,151.50	47.0%
Prevention (P1→P2)	+ RBAC, malware and VPN defenses	915.00	57.9%
Prevention + Response (RE2)	+ Redundant server, mirror site	725.48	66.6%
Mixed, first move (2FA)	Branch from Scenario 3	934.50	57.0% (18.8% from Scenario 3)

Total Asset Risk fell 66.6% overall, from 2,171.50 to 725.48. Measured from the Scenario 3 baseline, Prevention alone reduced risk by 20.5% and Prevention plus Response by 37.0%. Weak Password Transmission (V1), present on three of four Critical Assets, ranked as the highest-risk vulnerability at every stage. Existing and proposed controls reduce its impact but do not remove the exposure of intercepted credentials.

Recommendation: Adopt a Mixed Strategy. Deploy two-factor authentication first, since it alone achieves 18.8% reduction, nearly matching both Prevention steps combined (20.5%). Then apply Response controls (redundant infrastructure) to whichever Critical Asset carries the highest residual risk at that point.

Foundational Inventories

Asset Inventory

Asset Number	Asset Name	Asset Value	Description
A1	Financial Resources (Payroll Funds)	95	The government funds managed and distributed by HGA to employees in the form of paychecks. This is the most critical asset since HGA's primary mission is payroll processing.
A2	Personnel Information (Employee Database)	90	A database stored on the mainframe containing sensitive employee records such as service dates, leave balances, and salary. High value due to confidentiality and compliance requirements.
A3	Personal Computers	75	Desktop PCs used by HGA staff for daily operations like word processing, spreadsheets, and accessing applications. While essential for work, they are individually replaceable and supported with spares.
A4	LAN Server	90	The central server of the HGA LAN provides shared storage, applications, time and attendance processing, and e-mail services. It enforces access controls and is vital to system availability and integrity.
A5	Router (Internet Connectivity)	80	The network device that connects the LAN to the Internet, enabling e-mail and external communication. It also performs packet filtering and basic access control. Important but not as mission critical as payroll.
A6	Administrator Console	90	A dedicated management console used exclusively by system administrators to configure the server, create and delete user accounts, and perform privileged maintenance functions. Highly sensitive to compromise.
A7	Mainframe System (Payroll & Multiagency Processing)	95	A multiagency mainframe connected via the WAN that processes payroll and stores personnel databases. It is critical for issuing paychecks and coordinating with other government agencies.
A8	Audit Logs	80	System-generated logs that record user activity and administrative actions on the server. They are key for detecting security violations, supporting investigations, and maintaining accountability.

A9	Backups (Magnetic Tape Archives)	90	Backups of the LAN server's data, stored on magnetic tapes and transported offsite weekly. They ensure recovery in case of accidental data corruption, system failure, or disaster.
A10	Contingency Plans	85	Formal plans outlining procedures, resources, and responsibilities for maintaining continuity of operations during system outages, disasters, or emergencies. They are critical for resilience and recovery.

Note on Critical Asset Selection: All ten assets in this inventory carry relatively high values (75–95), reflecting that HGA's core systems are, in absolute terms, high-stakes by nature, this is a payroll and personnel data agency, not one with a wide spread of trivial and critical assets. Rather than forcing an artificial order-of-magnitude gap that wouldn't reflect a realistic organization, the four Critical Assets are selected as the *highest-value subset relative to the other six*, based on their centrality to HGA's core mission (payroll processing) and the severity of impact if compromised.

Threat Inventory

Threat Number	Threat Name	Threat Description
T1	Payroll Fraud	Submitting fraudulent time sheets, falsifying service records, or creating fictitious employees to divert payroll funds.
T2	Payroll Errors	Mistakes in entering or updating employee data, accidental corruption or loss of time and attendance records, or errors in interagency processing leading to incorrect or missed paychecks.
T3	Interruption of Operations	Power outages, construction accidents, natural disasters, or equipment malfunctions that disrupt payroll processing, LAN/WAN connectivity, or system availability.
T4	Malicious Insider or Disgruntled Employee	Insiders misusing access to delete accounts, misconfigure controls, insert fraudulent data, plant malware, or sabotage payroll operations.
T5	External Network Attacks	Unauthorized attempts from outside attackers via Internet, WAN, or dial-in connections aiming to penetrate systems, steal data, modify files, or disrupt services.
T6	Theft of Equipment	Physical theft of PCs, servers, or network devices, resulting in loss of availability and potential compromise of sensitive information.
T7	Malware Contamination	Introduction of viruses or malicious code that can corrupt, destroy, or exfiltrate payroll and personnel data.

T8	Disclosure or Brokerage of Information	Unauthorized disclosure, leakage, or sale of sensitive personnel or payroll data to third parties, damaging employee privacy and organizational reputation.
----	--	---

Security Vulnerabilities Inventory

Vulnerability Number	Vulnerability Description
V1	Weak Password Transmission – Passwords sent in clear text, easily intercepted.
V2	Inadequate Access Controls – Immature or misconfigured server permissions.
V3	Policy Non-Compliance – Users ignore security rules (e.g., leaving PCs logged in).
V4	Limited Audit Logging – Logs insufficient to track or investigate activity.
V5	Reliance on External Systems – Dependent on WAN and mainframe outside HGA's control.
V6	Weak Contingency Planning – Plans exist but are poorly tested and staff unaware.
V7	Outdated/Unpatched Software – Delays in applying security updates and fixes.
V8	Malware Exposure – Limited virus scanning and weak software control.
V9	LAN Eavesdropping – Data on LAN transmitted unencrypted, vulnerable to sniffers.
V10	Physical Security Gaps – Equipment and media vulnerable to theft or tampering.

Current Security Controls and Policies

CSCP Number	Category	Description
CSCP1	Payroll Fraud	Separation of Duties: Clerks enter data, supervisors review and approve, preventing fraud.
CSCP2	Payroll Fraud	Double Data Entry of Time Sheets: Clerks must enter each time sheet twice to reduce errors.
CSCP3	Payroll Fraud	Supervisor Review: Supervisors validate and sign time sheets before payroll submission.
CSCP4	Payroll Fraud	Server Access Controls: Only authorized payroll applications can transmit to mainframe.
CSCP5	Payroll Fraud	Restricted Payroll PCs: Payroll app functions limited to specific PCs during office hours.
CSCP6	Disclosure/Brokering Information	Need-to-Know Policy: Personnel and payroll data accessible only to authorized roles.
CSCP7	Disclosure/Brokering Information	Group-Based Access Controls: Users assigned to groups with restricted file access rights.
CSCP8	Disclosure/Brokering Information	Security Awareness Training: New users must complete mandatory training before system access.

CSCP9	Payroll Fraud	Password Policies: Users must change passwords periodically and keep them secret.
CSCP10	Payroll Fraud	Audit Log Reviews: COG staff review server logs regularly to detect violations.
CSCP11	Network-Related Threats	Router Packet Filtering: Router blocks non-email traffic between LAN and Internet.
CSCP12	Network-Related Threats	Dial-in Restrictions: Modem pool allows e-mail only, blocking remote login sessions.
CSCP13	Malware/Software Security:	Monthly Virus Scanning: System administrators run virus scans on servers and spot-check PCs.
CSCP14	Malware/Software Security:	Approved Software Policy: Only licensed, COG-approved software may be installed.
CSCP15	Payroll Error	Timely Patch Management: Vendor bug fixes and security patches installed on servers.
CSCP16	Payroll Error	WAN Error Checking: WAN protocols include error checking for payroll data transfers.
CSCP17	Payroll Error	Payroll Exception Reports: Mainframe payroll app flags missing or invalid time sheet data.
CSCP18	Payroll Error	Read-Only Payroll Data Retention: Payroll data stored on LAN server in read-only mode after submission.
CSCP19	Continuity of Operations	Daily & Weekly Backups: server backups with tapes transported weekly to offsite storage.
CSCP20	Continuity of Operations	Contingency Planning Requirement: COG and divisions must develop and test continuity of operations plans.

New Security Controls and Policies

NSCP Number	Category	Description
NSCP1	Payroll Fraud	Use of stronger authentication (e.g., smart tokens/one-time passwords) to prevent password interception.
NSCP2	Payroll Fraud	Improve administrators' patch management to quickly install vendor security fixes.
NSCP3	Payroll Fraud	Implement digital signatures on payroll/time data to detect unauthorized modifications.
NSCP4	Payroll Fraud	Establish strict compliance audits and penalties for falsified time sheets.
NSCP5	Payroll Errors	Require quarterly compliance audits of payroll records.
NSCP6	Payroll Errors	Enforce stricter deadlines and penalties for late personnel paperwork submissions.
NSCP7	Interruption of Operations	Conduct periodic internal training and contingency plan rehearsals for COG personnel.

NSCP8	Interruption of Operations	Deploy automated workstation backup reminders to all PCs weekly.
NSCP9	Interruption of Operations	Expand cooperative agreements with nearby agencies for shared computing capacity in disasters.
NSCP10	Malicious Insider / Disclosure	Install redundant LAN cabling paths to prevent accidental cable cuts during construction.
NSCP11	Malicious Insider / Disclosure	Improve frequency of mandatory security awareness training.
NSCP12	Malicious Insider / Disclosure	Install automatic screen-lock software on PCs after idle timeout.
NSCP13	Malicious Insider / Disclosure	Introduce stricter enforcement of clean desks and secure storage policy for sensitive files.
NSCP14	Malicious Insider / Disclosure	Require encryption of time and attendance files stored on PCs/servers.
NSCP15	External Network Attacks	Replace the current modem pool with encrypting modems for dial-in access.
NSCP16	External Network Attacks	Implement WAN encryption for payroll transmissions to the mainframe.
NSCP17	External Network Attacks	Require multi-factor authentication for remote/dial-in sessions.
NSCP18	Malware & Outdated Software	Strengthen enforcement of monthly virus scanning and reporting compliance.
NSCP19	Malware & Outdated Software	Establish penalties for unauthorized installation of non-approved software.
NSCP20	Audit & Monitoring	Require regular review of LAN server and mainframe audit logs using query tools.

Top 4 Assets, Threats and Vulnerabilities

Critical Assets

Asset Number	Asset Name	Asset Description	Asset Value
A1	Financial Resources (Payroll Funds)	The government funds managed and distributed by HGA to employees in the form of paychecks. This is the most critical asset since HGA's primary mission is payroll processing.	95
A2	Personnel Information (Employee Database)	A database stored on the mainframe containing sensitive employee records such as service dates, leave balances, and salary. High value due to confidentiality and compliance requirements.	90
A4	LAN Server	The central server of the HGA LAN provides shared storage, applications, time and	90

		attendance processing, and e-mail services. It enforces access controls and is vital to system availability and integrity.	
A7	Mainframe System (Payroll & Multiagency Processing)	A multiagency mainframe connected via the WAN that processes payroll and stores personnel databases. It is critical for issuing paychecks and coordinating with other government agencies.	95

Threats

Threat Number	Threat Name	Threat Description
T1	Payroll Fraud	Submitting fraudulent time sheets, falsifying service records, or creating fictitious employees to divert payroll funds.
T2	Payroll Errors	Mistakes in entering or updating employee data, accidental corruption or loss of time and attendance records, or errors in interagency processing leading to incorrect or missed paychecks.
T5	External Network Attacks	Unauthorized attempts from outside attackers via Internet, WAN, or dial-in connections aiming to penetrate systems, steal data, modify files, or disrupt services.
T7	Malware Contamination	Introduction of viruses or malicious code that can corrupt, destroy, or exfiltrate payroll and personnel data.

Vulnerabilities

Vulnerability Number	Vulnerability Description
V1	Weak Password Transmission – Passwords sent in clear text, easily intercepted.
V2	Inadequate Access Controls – Immature or misconfigured server permissions.
V7	Outdated/Unpatched Software – Delays in applying security updates and fixes.
V8	Malware Exposure – Limited virus scanning and weak software control.

A/T/V Likelihood Table: Stated Assumptions

1. Likelihood values represent the probability of successful exploitation of a Threat/Vulnerability pair as a mechanism, independent of which Critical Asset it lands on. Likelihood is a property of *how exploitable* vulnerability is against a given

threat, not of asset value. Asset-specific consequence (how much damage results) is captured separately in the A/RI(T/V) Impact table, where the same T/V pair can carry different impact percentages depending on which asset is affected. This is why this table has one row per Vulnerability × 4 Threat columns, rather than a full Asset × Threat × Vulnerability cube.

2. A1 (Payroll Funds) is intangible and only exposed through the systems that process it (A4, A7). A1 inherits exposure from vulnerabilities that enable unauthorized access or manipulation of transactions, authentication weaknesses (V1) and access-control bypass (V2) because these directly enable fraudulent diversion of funds. V7 (Outdated/Unpatched Software) is excluded from A1 because unpatched software primarily causes instability, crashes, or data corruption on the *host system* (A2/A4/A7) rather than a direct mechanism for diverting funds; that risk is already captured in A4/A7's own residual risk rather than duplicated onto A1.

A/T/V Table: Likelihood (%)

Vulnerability	T1 – Payroll Fraud	T2 – Payroll Errors	T5 – External Attacks	T7 – Malware
V1 – Weak Password Transmission	80%	60%	75%	65%
V2 – Inadequate Access Controls	70%	65%	60%	55%
V7 – Outdated/Unpatched Software	65%	60%	55%	70%
V8 – Malware Exposure	60%	55%	50%	85%

1. **Payroll Fraud (T1)** is assigned relatively high probabilities across vulnerabilities because it is one of the most critical risks for HGA. Weak password transmission (80%) creates a serious avenue for fraud since credentials can be intercepted on the LAN and reused to submit falsified timesheets. Inadequate access controls (70%) are also a major contributor, as misconfigured permissions allow clerks or supervisors to bypass separation-of-duty policies and manipulate payroll records. Outdated or unpatched payroll applications (65%) add another layer of risk, since attackers or insiders could exploit software flaws to modify financial data. Finally, malware exposure (60%) is moderately likely to support fraud, where malicious code could insert or modify bogus employee accounts or payroll entries.
2. **Payroll Errors (T2)** are more frequent than fraud and are assigned moderate-to-high probabilities across the vulnerabilities. Weak password transmission (60%) can

indirectly lead to errors when the wrong accounts are accessed or hijacked during processing. Inadequate access controls (65%) heighten the likelihood of errors when unauthorized staff can alter records without proper oversight. Unpatched systems (60%) increase error risk through instability, bugs, or crashes that corrupt payroll data. Malware exposure (55%) contributes as well, since viruses can inadvertently alter or delete payroll files, leading to mistakes in calculations or reporting.

3. **External Network Attacks (T5)** are considered highly probable where vulnerabilities directly expose systems to outsiders. Weak password transmission (75%) presents the highest risk, as attackers can sniff clear-text LAN/WAN credentials and gain unauthorized access. Inadequate access controls (60%) also leave openings for attackers to exploit once they are inside the network. Outdated or unpatched software (55%) is a known gateway for intrusion, since attackers often rely on exploiting publicly available vulnerabilities. Malware exposure (50%) is somewhat lower but still significant, as many external attacks involve planting malware to establish persistence or steal data.

4. **Malware Contamination (T7)** is judged as the most consistent threat across vulnerabilities. Weak password transmission (65%) allows malware to propagate by hijacking user credentials. Inadequate access controls (55%) let malware spread further once inside by escalating privileges. Unpatched software (70%) represents one of the most common infection points, as attackers target outdated operating systems and applications. Malware exposure (85%) has the highest likelihood overall, since HGA's limited virus scanning and weak software control make it extremely likely that malicious code will infect systems and cause corruption, exfiltration, or downtime.

Mapping: Asset/Vulnerability Pairs

Asset Number	Asset Name	Vulnerability Number	Vulnerability Description
A1	Financial Resources (Payroll Funds)	V1	Weak Password Transmission – Payroll access credentials can be intercepted.
		V2	Inadequate Access Controls – Poor permissions allow unauthorized payroll changes or fraud.
A2	Personnel Information (Employee Database)	V2	Inadequate Access Controls – Weak restrictions allow unauthorized modification of employee records.
		V7	Outdated/Unpatched Software – Database software left vulnerable to known exploits.

A4	LAN Server	V1	Weak Password Transmission – Cleartext LAN credentials exposed to sniffers.
		V8	Malware Exposure – Malware can spread via shared LAN applications.
A7	Mainframe System (Payroll & Multiagency Processing)	V2	Inadequate Access Controls – Misconfigured multiagency access permissions increase risk.
		V7	Outdated/Unpatched Software – Payroll/mainframe applications not patched promptly.
		V1	Weak Password Transmission – WAN-based logins vulnerable to interception.

Mapping: Risk Impact Table

A	T1* V1	T1* V2	T1* V7	T1* V8	T2* V1	T2* V2	T2* V7	T2* V8	T5* V1	T5* V2	T5* V7	T5* V8	T7* V1	T7* V2	T7* V7	T7* V8
A1	100	100	0	0	100	100	0	0	100	100	0	0	100	100	0	0
A2	0	100	100	0	0	100	100	0	0	100	100	0	0	100	100	0
A4	100	0	0	100	100	0	0	100	100	0	0	100	100	0	0	100
A7	100	100	100	0	100	100	100	0	100	100	100	0	100	100	100	0

Note: If a vulnerability is present on a Critical Asset, RI is set to 100% across every threat that can exploit it, because at this stage no controls have been applied yet, and we're establishing the absolute worst case. Resilience is 0% everywhere a 100 appears. Where a vulnerability doesn't exist on an asset (e.g., V7 isn't present on A1 or A4), RI is 0, there's no exposure to score.

Scenario 1: Residual Risk with HGA's Current Security Posture

We start from the worst-case TV (likelihood) and RI (impact) values established earlier, then apply HGA's *current* controls (CSCP1–20) to bring them down to a more realistic level. Controls that reduce how likely an exploit succeeds discount TV; controls that reduce how much damage results discount RI. Reductions aren't uniform, they're sized based on how well each control is actually enforced, not just whether it exists on paper. This gives us Scenario 1's Residual Critical Asset Risk, Total Asset Risk, and Vulnerability Risk, each with a ranking to show which assets and vulnerabilities carry the most risk once current controls are accounted for.

	T1 – Payroll Fraud	T2 – Payroll Errors	T5 – External Attacks	T7 - Malware
V1 (Weak Password Transmission) on A1, A4, A7	80	60	75	65
V2 (Inadequate Access Controls) on A1, A2, A4, A7	70	65	60	55
V7 (Outdated/Unpatched Software) on A2, A4, A7)	65	60	55	70
V8 (Malware Exposure) on A1, A2, A4, A7	60	55	50	85

Residual Asset Risk

$$Risk(A_n) = Asset\ Value \times (\sum TV\% \text{ for all Threat/Vulnerability pairs linked to } A_n) \div 100$$

Residual Asset Risk		
Asset Number	Asset Value	Residual Asset Risk
A1	95	741.00
A2	90	675.00
A4	90	927.00
A7	95	978.50

Residual Vulnerability Risk

$$Risk(V_n) = \sum [Vulnerable\ Asset\ Value \times (Sum\ of\ row\ of\ Threats)] \div 100$$

Vulnerability Number	Residual Vulnerability Risk
V1 on A1, A4, A7	784
V2 on A1, A2, A4, A7	925
V7 on A2, A4, A7	687.5
V8 on A1, A2, A4, A7	925

Ranking Residual Risks

Residual Asset Risk			
Asset Number	Asset Value	Residual Asset Risk	Rank
A7	95	978.50	1
A4	90	927.00	2
A1	95	741.00	3
A2	90	675.00	4

Residual Vulnerability Risk		
Vulnerability Number	Residual Vulnerability Risk	Rank
V2 on A1, A2, A4, A7	925	1
V8 on A1, A2, A4, A7	925	2
V1 on A1, A4, A7	784	3
V7 on A2, A4, A7	687.5	4

Residual risk is computed by weighting each Critical Asset's value against the combined likelihood of all Threat/Vulnerability pairs tied to its vulnerabilities, and by weighting each Vulnerability's exploitability against the value of every asset it touches. This surfaces two views of the same exposure which assets carry the most risk, and which vulnerabilities drive the most risk across the environment using consistent inputs, so the rankings are directly comparable to later scenarios.

A7 (Mainframe) and A4 (LAN Server) carry the highest residual asset risk, both exposed to all four selected vulnerabilities, while A1 and A2 trail with three each. At the vulnerability level, V2 (Inadequate Access Controls) and V8 (Malware Exposure) tie for the highest residual risk, followed by V1 and V7 indicating that, prior to any new or optimized controls, HGA's largest

exposure comes from access-control weaknesses and malware susceptibility spread across nearly every critical system, rather than from any single isolated weak point.

Scenario 2: Residual Risk with New CISO's Controls Applied

We start from Scenario 1's TV values, then layer in the New Controls (NC) proposed by the new CISO and team. Where a New Control applies to a given Threat/Vulnerability pair, it further discounts either TV or RI beyond what current controls already achieved. This gives us Scenario 2's updated Residual Critical Asset Risk, Total Asset Risk, and Vulnerability Risk, each re-ranked to show how the new recommendations shift priority compared to Scenario 1.

	T1 – Payroll Fraud	T2 – Payroll Errors	T5 – External Attacks	T7 - Malware
V1 (Weak Password Transmission) on A1, A4, A7	55	45	50	45
V2 (Inadequate Access Controls) on A1, A2, A4, A7	50	45	45	40
V7 (Outdated/Unpatched Software) on A2, A4, A7)	40	40	35	45
V8 (Malware Exposure) on A1, A2, A4, A7	40	35	30	55

Residual Asset Risk

$$Risk(A_n) = Asset\ Value \times (\Sigma TV\% \text{ for all Threat/Vulnerability pairs linked to } A_n) \div 100$$

Residual Asset Risk		
Asset Number	Asset Value	Residual Asset Risk
A1	95	508.25
A2	90	450.00
A4	90	625.50
A7	95	660.25

Residual Vulnerability Risk

$$Risk(V_n) = \Sigma [Vulnerable\ Asset\ Value \times (Sum\ of\ row\ of\ Threats)] \div 100$$

Vulnerability Number	Residual Vulnerability Risk
V1 on A1, A4, A7	536.25
V2 on A1, A2, A4, A7	721.5
V7 on A2, A4, A7	495
V8 on A1, A2, A4, A7	592

Ranking Residual Risks

Residual Asset Risk			
Asset Number	Asset Value	Residual Asset Risk	Ranking
A7	95	660.25	1
A4	90	625.50	2
A1	95	508.25	3
A2	90	450.00	4

Residual Vulnerability Risk		
Vulnerability Number	Residual Vulnerability Risk	Rank
V2 on A1, A2, A4, A7	721.5	1
V8 on A1, A2, A4, A7	592	2
V1 on A1, A4, A7	536.25	3
V7 on A2, A4, A7	495	4

Applying the new CISO's controls further discounts the TV values across all four vulnerabilities, so each Threat/Vulnerability percentage in Scenario 2 sits meaningfully below Scenario 1's. The same asset-value-weighted formula is reused for consistency, isolating the effect of the new controls rather than changing how risk is measured.

Every asset and vulnerability shows a lower residual risk than in Scenario 1, confirming the new CISO's recommendations are effective overall. The ranking order stays identical to Scenario 1 at both the asset level (A7 > A4 > A1 > A2) and the vulnerability level (V2 > V8 > V1 > V7) — the new controls reduce the *magnitude* of risk but don't change *where* HGA's priorities should be. Access-control weaknesses (V2) and malware exposure (V8) remain

the top two vulnerability concerns, and the Mainframe (A7) and LAN Server (A4) remain in the top two asset concerns.

Scenario 3: Residual Risk with Management-Operational-Technical (MOT) Controls

We start from Scenario 2's TV and RI values, then layer in Management-Operational-Technical (MOT) controls, in addition to the current and new CISO controls already applied. Where an MOT control applies to a given Threat/Vulnerability pair, it further discounts TV or RI beyond Scenario 2's levels. This gives us Scenario 3's updated Residual Critical Asset Risk, Total Asset Risk, and Vulnerability Risk, each re-ranked to show how compliance-driven MOT controls shift priority compared to Scenario 2.

Management	Policies
	Governance
	Strict Compliance Audits
	Management Monitoring
Operational	Awareness Training
	Incident Response
	Segregation of duties
Technical	Encryption
	IDS/IPS
	Multi-Factor Authentication
	Automated Patching

	T1 – Payroll Fraud	T2 – Payroll Errors	T5 – External Attacks	T7 - Malware
V1 (Weak Password Transmission) on A1, A4, A7	45	35	40	35
V2 (Inadequate Access Controls) on A1, A2, A4, A7	40	35	35	30
V7 (Outdated/Unpatched Software) on A2, A4, A7)	30	30	25	35
V8 (Malware Exposure) on A1, A2, A4, A7	30	25	20	40

Residual Asset Risk

$$Risk(A_n) = Asset\ Value \times (\Sigma TV\% \text{ for all Threat/Vulnerability pairs linked to } A_n) \div 100$$

Residual Asset Risk		
Asset Number	Asset Value	Residual Asset Risk
A1	95	389.50
A2	90	337.50
A4	90	477.00
A7	95	503.50

Residual Vulnerability Risk

$$Risk(V_n) = \Sigma [Vulnerable\ Asset\ Value \times (Sum\ of\ row\ of\ Threats)] \div 100$$

Vulnerability Number	Residual Vulnerability Risk
V1 on A1, A4, A7	426.25
V2 on A1, A2, A4, A7	573.5
V7 on A2, A4, A7	385
V8 on A1, A2, A4, A7	444

Ranking Residual Risks

Residual Asset Risk			
Asset Number	Asset Value	Residual Asset Risk	Ranking
A7	95	503.50	1
A4	90	477.00	2
A1	95	389.50	3
A2	90	337.50	4

Residual Vulnerability Risk		
Vulnerability Number	Residual Vulnerability Risk	Rank
V2 on A1, A2, A4, A7	573.5	1
V8 on A1, A2, A4, A7	444	2
V1 on A1, A4, A7	426.25	3

V7 on A2, A4, A7	385	4
------------------	-----	---

Layering MOT controls (Management: governance, audits, monitoring; Operational: awareness training, incident response, segregation of duties; Technical: encryption, IDS/IPS, MFA, automated patching) on top of Scenario 2's already-reduced values further discounts every Threat/Vulnerability percentage. This reflects RMF/compliance-driven controls addressing gaps that current and CISO-proposed controls alone didn't fully close the same formula is reused so the comparison across scenarios stays apples-to-apples.

Residual risk continues to decline across all assets and vulnerabilities, with Total Asset Risk dropping further from Scenario 2. The ranking order remains unchanged at both levels $A7 > A4 > A1 > A2$ for assets, and $V2 > V8 > V1 > V7$ for vulnerabilities showing that MOT controls compress the *magnitude* of risk without altering *where* the priority sits. This consistency across three scenarios (current controls → CISO controls → MOT controls) signals that access-control weaknesses and malware exposure are structural risk drivers for HGA, not artifacts of any one control layer, and will likely remain the natural targets when Prevention and Response strategies are applied next.

Scenario 4 (Prevention Step P1): Applying RBAC to the Highest-Risk Vulnerability

In Scenario 3, V2 – Inadequate Access Controls was identified as the highest residual vulnerability risk, affecting critical assets such as Payroll Funds, the Employee Database, and the Mainframe. This weakness stems from poor enforcement of user privileges, misconfigured permissions, and insufficient oversight of access rights. Such gaps increase the likelihood of payroll fraud, erroneous modifications, and unauthorized intrusions. To address this, the prevention strategy introduces a stronger Role-Based Access Control (RBAC) system combined with regular compliance audits. RBAC ensures that users are only granted the minimum level of access required for their duties, thereby reducing opportunities for misuse. Meanwhile, compliance audits provide ongoing monitoring to detect and correct deviations in access assignments before they escalate into incidents.

Alongside RBAC and audits, the prevention step incorporates operational improvements such as stricter segregation of duties, automated account provisioning and de-provisioning, and periodic access reviews by management. These measures significantly decrease the probability of unauthorized changes or exploitation of access rights, without altering the impact values associated with V2. In practical terms, the effect of these controls is a reduction in the probability scores linked to V2 across all threats, thereby

lowering its contribution to overall organizational risk. This demonstrates how targeted management and operational controls can meaningfully strengthen the security posture by directly addressing the most critical vulnerability.

T/V Table				
	T1	T2	T5	T7
V1 on A1, A4, A7	45	35	40	35
V2 on A1, A2, A4, A7	20	15	15	20
V7 on A2, A4, A7	30	30	25	35
V8 on A1, A2, A4, A7	30	25	20	40

Residual Asset Risk

$$Risk(A_n) = Asset\ Value \times (\Sigma TV\% \text{ for all Threat/Vulnerability pairs linked to } A_n) \div 100$$

Residual Asset Risk		
Asset Number	Asset Value	Residual Asset Risk
A1	95	323.00
A2	90	274.50
A4	90	414.00
A7	95	437.00

Residual Vulnerability Risk

$$Risk(V_n) = \Sigma [Vulnerable\ Asset\ Value \times (Sum\ of\ row\ of\ Threats)] \div 100$$

Vulnerability Number	Residual Vulnerability Risk
V1 on A1, A4, A7	426.25
V2 on A1, A2, A4, A7	573.5
V7 on A2, A4, A7	275
V8 on A1, A2, A4, A7	444

Ranking Residual Risks

Residual Asset Risk			
Asset Number	Asset Value	Residual Asset Risk	Ranking
A7	95	437.00	1

A4	90	414.00	2
A1	95	323.00	3
A2	90	274.50	4

Residual Vulnerability Risk		
Vulnerability Number	Residual Vulnerability Risk	Rank
V8 on A1, A2, A4, A7	444	1
V1 on A1, A4, A7	426.25	2
V2 on A1, A2, A4, A7	259	3
V7 on A2, A4, A7	192.5	4

In Prevention Step P1, the introduction of new controls significantly shifted the vulnerability risk rankings. V8 (Malware Exposure) emerged as the highest residual vulnerability risk with a value of 444, followed closely by V1 (Weak Password Transmission) at 426.25. This reflects the fact that while previous measures such as RBAC and compliance audits (targeting V2) reduced access-related risks, malware remained a persistent challenge across multiple assets.

Meanwhile, V2 (Inadequate Access Controls), which was the top vulnerability in Scenario 3, dropped to third place (259) due to the effectiveness of RBAC and audit-based prevention controls applied in P1. V7 (Outdated/Unpatched Software) continued to pose a lower risk at 192.5, given improvements from patch management processes. This demonstrates how targeted prevention strategies can realign the organization's risk profile, reduce critical vulnerabilities while highlight new priority areas such as malware defenses.

Scenario 5 (Prevention Step P2): Applying a VPN to the Highest-Risk Vulnerability

In Prevention Step P2, the focus shifted to V8 – Malware Exposure, which was identified as the highest residual vulnerability risk in P1. This vulnerability reflects the potential for malicious code to infiltrate and spread across HGA's systems, threatening the integrity of payroll, employee data, and shared LAN services. To mitigate this, the organization introduced stronger technical defenses, including enterprise endpoint protection, network segmentation, and VPN enforcement for external access. These measures were designed to block malware entry points, limit its spread within the network, and ensure all external

communications are encrypted. As a result, the threat probabilities linked to V8 were further reduced, lowering its overall contribution to the residual risk profile while elevating other vulnerabilities, such as weak password transmission (V1) and inadequate access controls (V2), as the new primary concerns.

T/V Table				
	T1	T2	T5	T7
V1 on A1, A4, A7	45	35	40	35
V2 on A1, A2, A4, A7	20	15	15	20
V7 on A2, A4, A7	30	30	25	35
V8 on A1, A2, A4, A7	20	15	15	20

Residual Asset Risk

$$Risk(A_n) = Asset\ Value \times (\Sigma TV\% \text{ for all Threat/Vulnerability pairs linked to } A_n) \div 100$$

Residual Asset Risk		
Asset Number	Asset Value	Residual Asset Risk
A1	95	280.25
A2	90	234.00
A4	90	373.50
A7	95	394.25

Residual Vulnerability Risk

$$Risk(V_n) = \Sigma [Vulnerable\ Asset\ Value \times (Sum\ of\ row\ of\ Threats)] \div 100$$

Vulnerability Number	Residual Vulnerability Risk
V1 on A1, A4, A7	426.25
V2 on A1, A2, A4, A7	259
V7 on A2, A4, A7	192.5
V8 on A1, A2, A4, A7	259

Ranking Residual Risks

Residual Asset Risk			
Asset Number	Asset Value	Residual Asset Risk	Ranking

A7	95	394.25	1
A4	90	373.50	2
A1	95	280.25	3
A2	90	234.00	4

Residual Vulnerability Risk		
Vulnerability Number	Residual Vulnerability Risk	Rank
V1 on A1, A4, A7	426.25	1
V2 on A1, A2, A4, A7	259	2
V8 on A1, A2, A4, A7	259	3
V7 on A2, A4, A7	192.5	4

In P2, the application of advanced malware defenses significantly lowered V8 (Malware Exposure) from its previously high levels of 444 to a residual risk of 259. This reduction reflects the impact of endpoint protection, VPN enforcement, and network segmentation in limiting malware propagation. As a result, V8 dropped in ranking, showing that targeted technical controls can effectively mitigate one of HGA's most persistent risks.

Scenario 6 (Optimized Risk Response Strategy RE1): Redundant server for the Mainframe System

We start from Prevention Step P2's TV values, which stay unchanged in RE1. This step targets Risk Impact (RI), not likelihood. A7 (Mainframe System) carries the highest Residual Asset Risk at P2 (327.75), so a Response control, a redundant failover server, supported by encrypted WAN connectivity and strong authentication for mainframe access is applied to reduce A7's impact by 35%, ensuring payroll and multiagency operations can continue uninterrupted even under attack or compromise. Since this is an asset-specific impact reduction rather than a change to the shared Threat/Vulnerability table, only A7's contribution including its share of V1, V2, and V7's totals is scaled down; A1, A2, and A4 remain exactly at their P2 values.

Residual Asset Risk

$$Risk(A_n) = Asset\ Value \times (\sum TV\% \text{ for all Threat/Vulnerability pairs linked to } A_n) \div 100$$

Residual Asset Risk			
Asset Number	P2 Risk	RE1 Risk	Rank
A1	213.75	213.75	1
A7	327.75	213.04	2
A4	202.50	202.50	3
A2	171.00	171.00	4

Total Asset Risk (RE1): 800.29 (down from 915.00 at P2 — a 12.6% reduction)

Residual Vulnerability Risk

Residual Vulnerability Risk			
Vulnerability	P2 Risk	RE1 Risk	Rank
V1	434.00	382.46	1
V7	222.00	182.10	2
V2	196.00	172.73	3
V8	63.00	63.00	4

Because A7 carries exposure to three of the four selected vulnerabilities (V1, V2, V7), reducing its impact pulls down each of those vulnerabilities' totals proportionally but V8 (only present on A4) is completely untouched, since A4 wasn't the target of this Response control.

The redundant server strategy successfully dethrones A7 from the top of the asset risk ranking but only just: A1 (213.75) and A7 (213.04) are now separated by less than 1 point, meaning A7 remains a near-tied top concern rather than a clearly resolved one.

Vulnerability risk *ranking order* is unaffected (V1 > V7 > V2 > V8 holds at both P2 and RE1), confirming that Response controls reshape *where* impact concentrates without changing *which* vulnerabilities are structurally most exploitable — that remains a Prevention-side problem. Total Asset Risk continues its downward trend (915.00 → 800.29), reinforcing that Response and Prevention strategies address different, complementary parts of the risk equation.

Scenario 7 (Optimized Risk Response Strategy RE2): Mirror Site with Automated Failover for Payroll Funds

We start from Response Step RE1's TV values, which stay unchanged in RE2, like RE1, only touches Risk Impact. A1 (Financial Resources/Payroll Funds) carries the highest Residual Asset Risk at RE1 (213.75), narrowly ahead of A7 (213.04), making it the target for this Response step. A mirror site with automated failover is applied specifically to A1, reducing its impact by 35% ensuring payroll disbursement can continue uninterrupted even if the primary system is compromised or unavailable. As with RE1, this reduction is applied only to A1's contribution across the vulnerabilities it touches (V1, V2); A2, A4, and A7 remain at their RE1 values.

Residual Asset Risk

$$Risk(A_n) = Asset\ Value \times (\sum TV\% \text{ for all Threat/Vulnerability pairs linked to } A_n) \div 100$$

Residual Asset Risk			
Asset Number	RE1 Risk	RE2 Risk	Rank
A7	213.04	213.04	1
A4	202.50	202.50	2
A2	171.00	171.00	3
A1	213.75	138.94	4

Total Asset Risk (RE1): 725.48 (down from 800.29 at RE1 — a 9.3% reduction)

Residual Vulnerability Risk

Residual Vulnerability Risk			
Vulnerability	RE1 Risk	RE2 Risk	Rank
V1	382.46	330.93	1
V7	182.10	182.10	2
V2	172.73	149.45	3
V8	63.00	63.00	4

Since A1 only touches V1 and V2, only those two vulnerability totals move; V7 and V8 are untouched because neither A2, A4, nor A7 were the targets of this step.

RE2 flips the asset ranking, A7 reclaims the top spot (213.04) now that A1 has been meaningfully reduced (213.75 → 138.94), illustrating a real tradeoff in sequential Response

strategies: fixing today's highest-risk asset doesn't eliminate risk, it reallocates the ranking to whichever asset wasn't just treated. Vulnerability ranking order is unchanged from RE1 ($V1 > V7 > V2 > V8$), reinforcing that V1 (Weak Password Transmission) remains the single largest structural risk driver across the entire Response strategy, a problem neither RE1 nor RE2 was designed to touch, since both targeted asset-level impact rather than the underlying likelihood. Total Asset Risk continues its downward trend ($800.29 \rightarrow 725.48$), bringing cumulative reduction from Scenario 3's baseline (1,151.50) to roughly 37% after two rounds of Response controls.

Scenario 8 (Optimized security Mixed Strategy): Candidate Controls from Scenario 3

We start from Scenario 3's TV and RI values and test four candidate controls independently, each applied as a standalone branch from the same Scenario 3 baseline, rather than stacked sequentially as in the Prevention/Response strategies. This isolates which single control delivers the greatest Total Asset Risk reduction on its own, before committing to a multi-step sequence. Each candidate targets the same control/vulnerability pairing used earlier: 1.1 (2FA $\rightarrow$ V1), 1.2 (VPN $\rightarrow$ V8), 1.3 (Redundant Server $\rightarrow$ A7), 1.4 (Mirror Site $\rightarrow$ A1).

8.1. 2FA (Targets V1, TV reduction, 50%)

Asset	Scenario 3 Risk	Step 8.1 Risk
A1	280.25	206.63
A2	234.00	234.00
A4	243.00	173.25
A7	394.25	320.63
Total	1151.50	934.50

8.2. VPN (Targets V8, TV reduction, 50%)

Asset	Scenario 3 Risk	Step 8.2 Risk
A1	280.25	280.25
A2	234.00	234.00
A4	243.00	191.25
A7	394.25	394.25
Total	1151.50	1099.75

8.3. Redundant Server (Targets A7, RI reduction, 35%)

Asset	Scenario 3 Risk	Step 8.3 Risk
-------	-----------------	---------------

A1	280.25	280.25
A2	234.00	234.00
A4	243.00	243.00
A7	394.25	256.26
Total	1151.50	1013.51

8.4. Mirror Site (Targets A1, RI reduction, 35%)

Asset	Scenario 3 Risk	Step 8.3 Risk
A1	280.25	182.16
A2	234.00	234.00
A4	243.00	243.00
A7	394.25	394.25
Total	1151.50	1053.41

Ranking of Total Asset Reduction

Step	Control	Total Risk Reduction	% Reduction
8.1	2FA	217.00	18.8%
8.2	Redundant Server	137.99	12%
8.3	Mirror Site	98.09	8.5%
8.4	VPN	51.75	4.5%

2FA produces the largest reduction because it directly targets V1, the single vulnerability present on three of the four Critical Assets (A1, A4, A7) under the corrected mapping, and consistently the highest-risk vulnerability at every prior stage. A control that hits a widely shared vulnerability compounds its benefit across multiple assets simultaneously, while Response controls (1.3, 1.4) only ever benefit the one asset they're applied to, and VPN (1.2) targets V8, the vulnerability with the narrowest footprint (only A4).

As a first step in an Optimized Mixed Strategy, 2FA should be prioritized ahead of Redundant Server, Mirror Site, or VPN. It delivers over 50% more risk reduction than the next-best option (Redundant Server) and over 4x the reduction of VPN. This reinforces the pattern seen throughout the entire assessment: addressing V1 (Weak Password Transmission) at its root, rather than containing its downstream impact per-asset, is HGA's single most cost-effective security investment.

Strategy Comparison

Strategy	Path	Starting Risk (Scenario 3)	Final Risk	Reduction	% Reduction
Prevention only	P1 → P2	1,151.50	915.00	236.50	20.5%
Prevention + Response	P1 → P2 → RE1 → RE2	1,151.50	725.48	426.02	37.0%
Mixed (first move only)	MOPT1 (2FA)	1,151.50	934.50	217.00	18.8%

Response steps (RE1, RE2) in this model start from Prevention's endpoint (P2), so the "Prevention + Response" row reflects both strategies combined, not Response in isolation. Mixed Strategy here reflects only its first step (MOPT1); further steps (MOPT2–4) weren't computed, so its full potential is understated in this comparison.

Assessment:

- **Prevention alone** delivers solid, moderate risk reduction (20.5%) by addressing likelihood at the source but leaves impact untouched; a successful attack still does full damage.
- **Adding Response** nearly doubles total reduction (37.0%) by addressing what happens *after* an exploit succeeds; the two are complementary, not competing, which is why combining them outperforms either alone.
- **Mixed Strategy's single first move (2FA)** achieves 18.8% reduction on its own — nearly matching full two-step Prevention (20.5%) with one control instead of two, the strongest reduction-per-control ratio of any option tested.

Recommendation: A **Mixed Strategy** is the strongest approach — not because it beat the others outright in this partial analysis, but because it's structurally designed to pick whichever control (Prevention or Response) delivers the most value at each step, rather than committing to a fixed sequence. Given MOPT1 (2FA) already rivals full Prevention in impact, the logical continuation is to follow it with the highest-value Response control next (targeting A7, the persistent top-risk asset) effectively building the same 37% combined reduction achieved above but arrived at through value-ranked steps rather than a rigid Prevention-then-Response order.

Summary Table

Stage	Total Asset Risk	Cumulative Reduction from Scenario 3
Scenario 1	2,171.50	—
Scenario 2	1,490.00	—
Scenario 3	1,151.50	— (baseline for all following steps)
Prevention P1	955.50	17.0%
Prevention P2	915.00	20.5%
Response RE1	800.29	30.5%
Response RE2	725.48	37.0%
Mixed MOPT1 (branch from Scenario 3)	934.50	18.8%

Conclusion

Across three baseline scenarios and two treatment strategies, HGA's Total Asset Risk fell from 2,171.50 at Scenario 1 to as low as 725.48 under combined Prevention and Response controls; a 37% reduction from the Scenario 3 baseline. V1 (Weak Password Transmission) remained the highest-risk vulnerability at every stage of the assessment, including after the new CISO's controls and MOT compliance measures were applied, indicating that HGA's existing and proposed controls reduce the *impact* of password-based exploitation without resolving its *root cause*, cleartext credential transmission. The Mixed Strategy's first move, 2FA targeting V1, achieved an 18.8% reduction on its own, nearly matching the full two-step Prevention strategy (20.5%) with a single control, making it the most efficient individual intervention identified in this assessment. A Mixed Strategy - 2FA first, followed by asset-targeted Response controls for whichever Critical Asset carries the highest residual risk at that point, offers the strongest overall risk reduction path, combining Prevention's efficiency in addressing likelihood with Response's resilience in containing impact.